Федеральное государственное автономное образовательное учреждение высшего образования «Национальный исследовательский университет ИТМО»

Информационная безопасность

Работа №4

«Анализ уязвимостей веб-приложения с помощью OWASP ZAP»

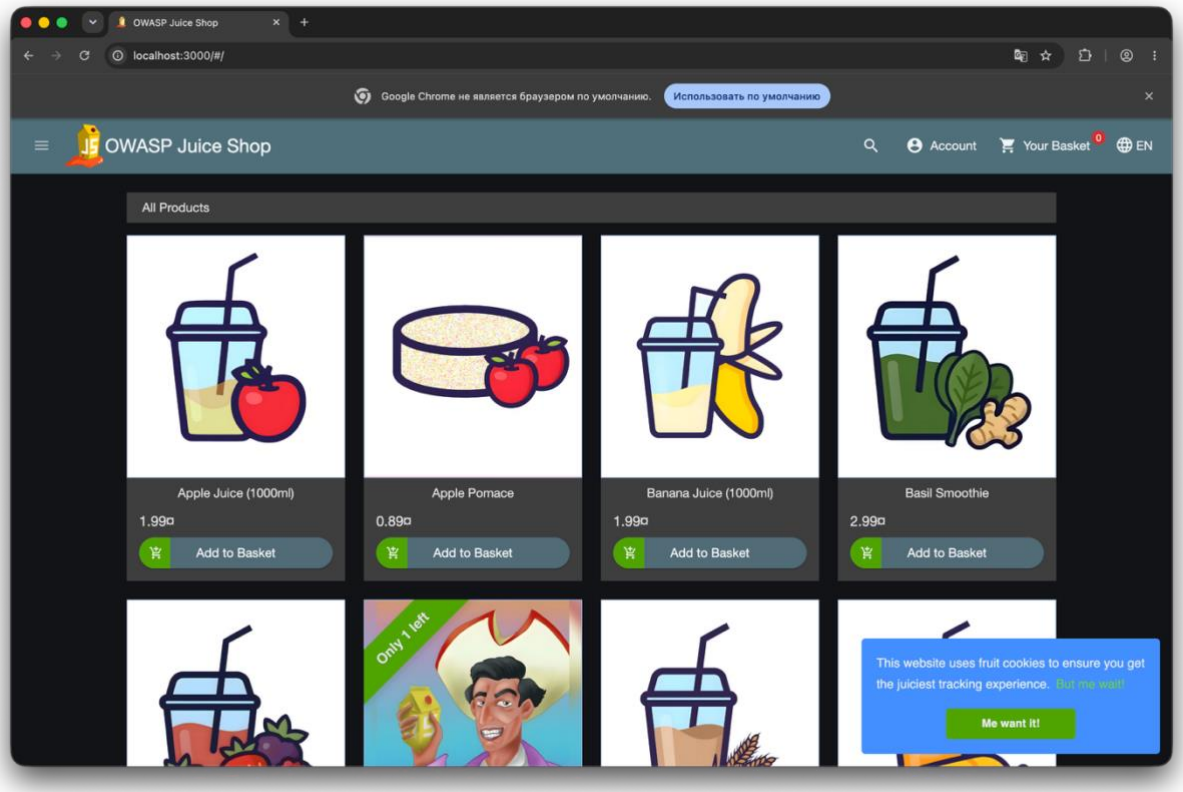
Выполнил: студент группы P3408,
Васильев Никита Алексеевич

2026

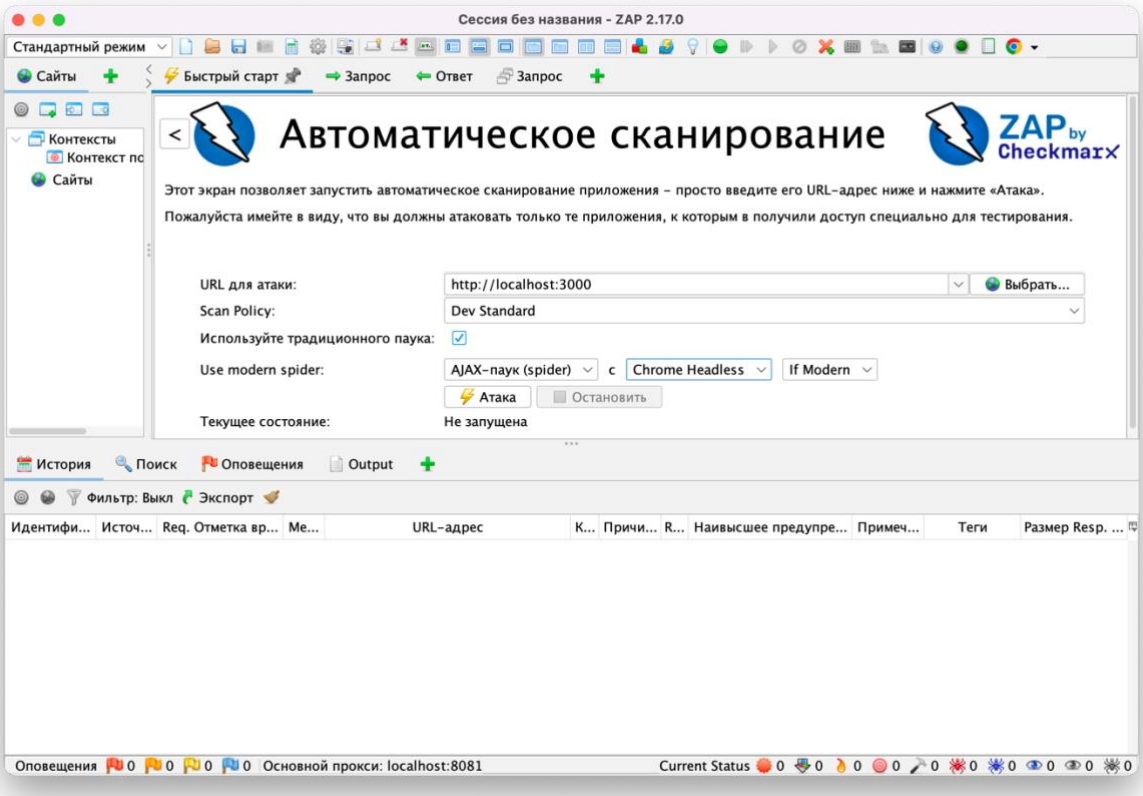
Для выполнения лабораторной работы был установлен и запущен OWASP ZAP версии 2.17.0 – инструмент для тестирования безопасности веб-приложений.

В качестве объекта исследования было принято решение использовать учебное веб-приложение OWASP Juice Shop, специально разработанное для изучения и тестирования веб-уязвимостей.

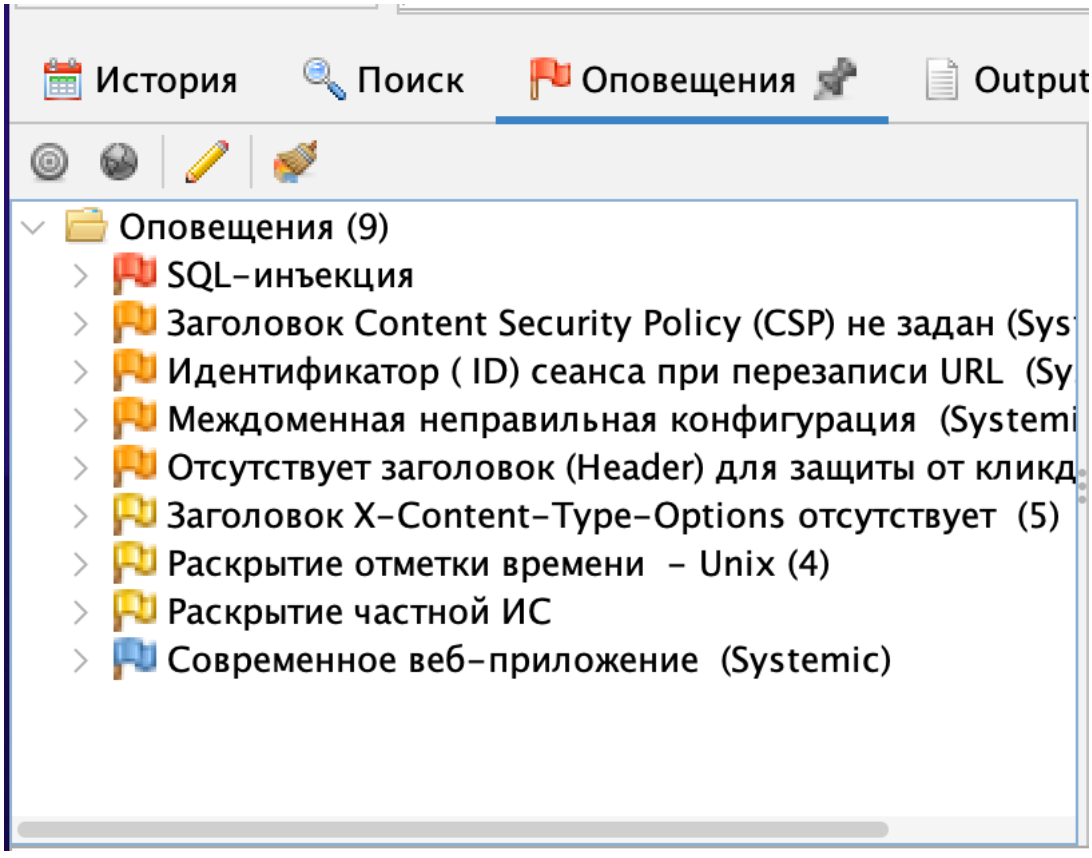
Приложение было запущено локально с помощью Docker и стало доступно по адресу `http://localhost:3000`. После запуска была проверена его работоспособность через браузер Google Chrome



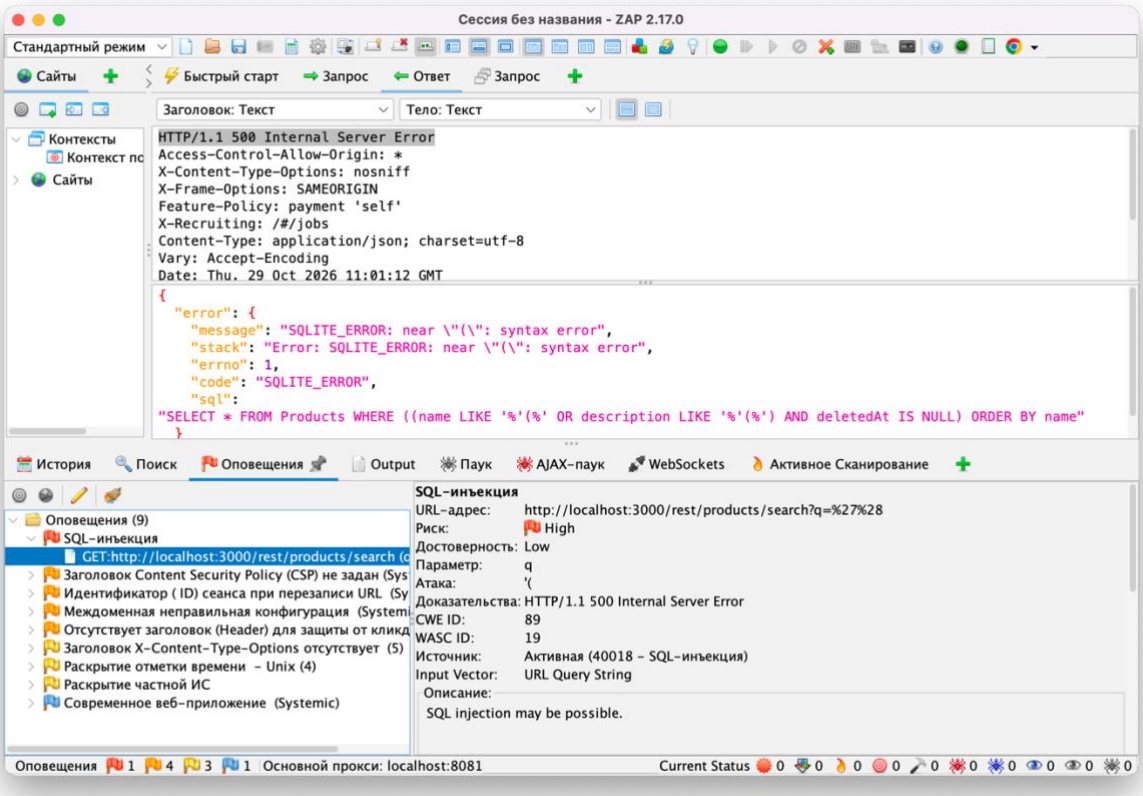
Далее был запущен OWASP ZAP. На вкладке «Быстрый старт» был выбран режим автоматического сканирования. В качестве целевого адреса указан `http://localhost:3000`. Для исследования структуры приложения были выбраны традиционный паук и современный AJAX-паук.



По результатам сканирования OWASP ZAP сформировал 9 различных типов оповещений о потенциальных проблемах безопасности. Обнаруженные предупреждения имели высокий, средний, низкий и информационный уровни риска.



Для дальнейшего анализа были выбраны пять типов предупреждений: SQL-инъекция, отсутствие заголовка Content Security Policy (CSP), неправильная конфигурация CORS, отсутствие защиты от кликджекинга и отсутствие заголовка X-Content-Type-Options.

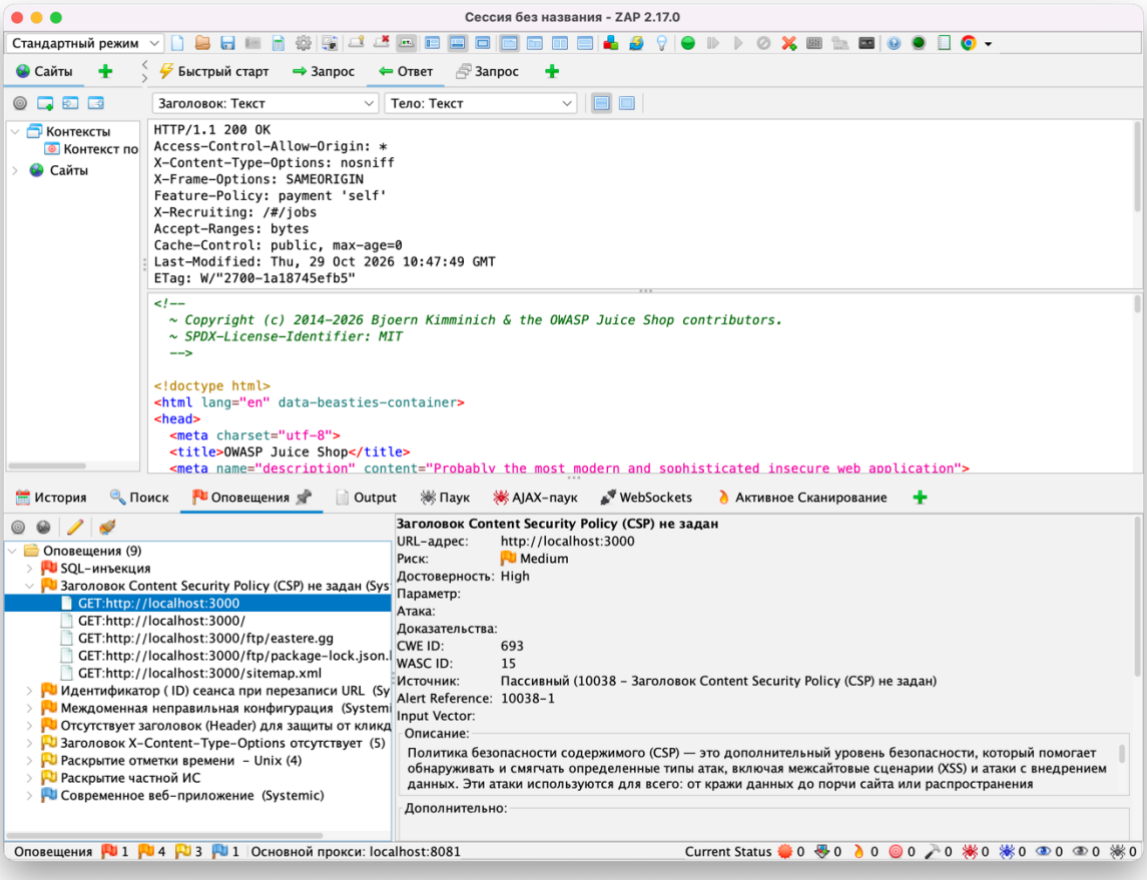


В ходе автоматического сканирования веб-приложения OWASP Juice Shop инструментом OWASP ZAP была обнаружена потенциальная уязвимость SQL Injection с высоким уровнем риска.

Уязвимость обнаружена в HTTP-запросе к `/rest/products/search`, использующем параметр `q` для поиска товаров. При передаче специально сформированного значения сервер вернул ответ `HTTP 500 Internal Server Error`, содержащий сообщение `SQLITE_ERROR` и фрагмент SQL-запроса.

Данная проблема свидетельствует о недостаточной защите обработки пользовательского ввода. При наличии эксплуатируемой SQL-инъекции злоумышленник потенциально может получить несанкционированный доступ к данным или изменить их.

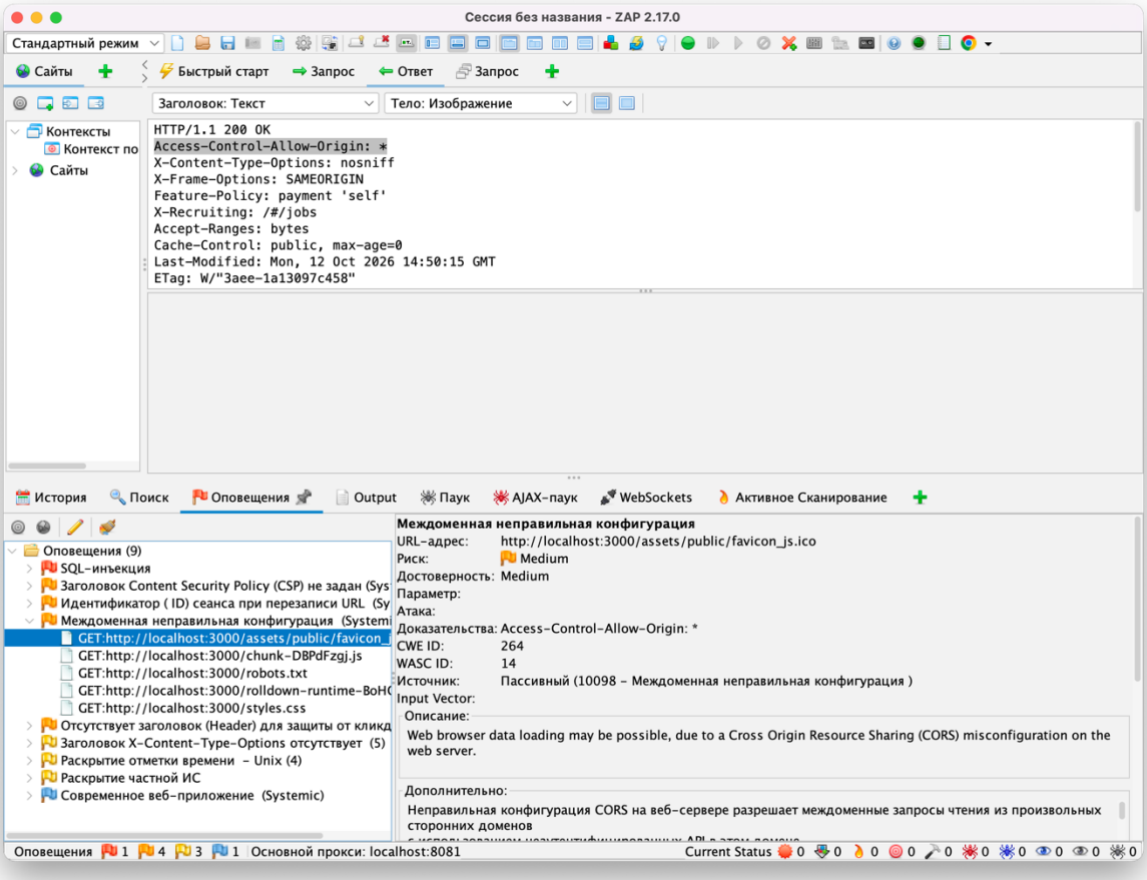
Для устранения уязвимости рекомендуется использовать параметризованные SQL-запросы и исключить прямое включение пользовательского ввода в SQL-выражения.



Проверка показала, что при обращении к `http://localhost:3000` сервер возвращает ответ `HTTP 200 OK`, однако не передаёт заголовок `Content-Security-Policy`.

Данный заголовок позволяет ограничивать источники загрузки и выполнения JavaScript, CSS и других ресурсов. Его отсутствие снижает защищённость веб-приложения от некоторых атак, в частности Cross-Site Scripting (XSS).

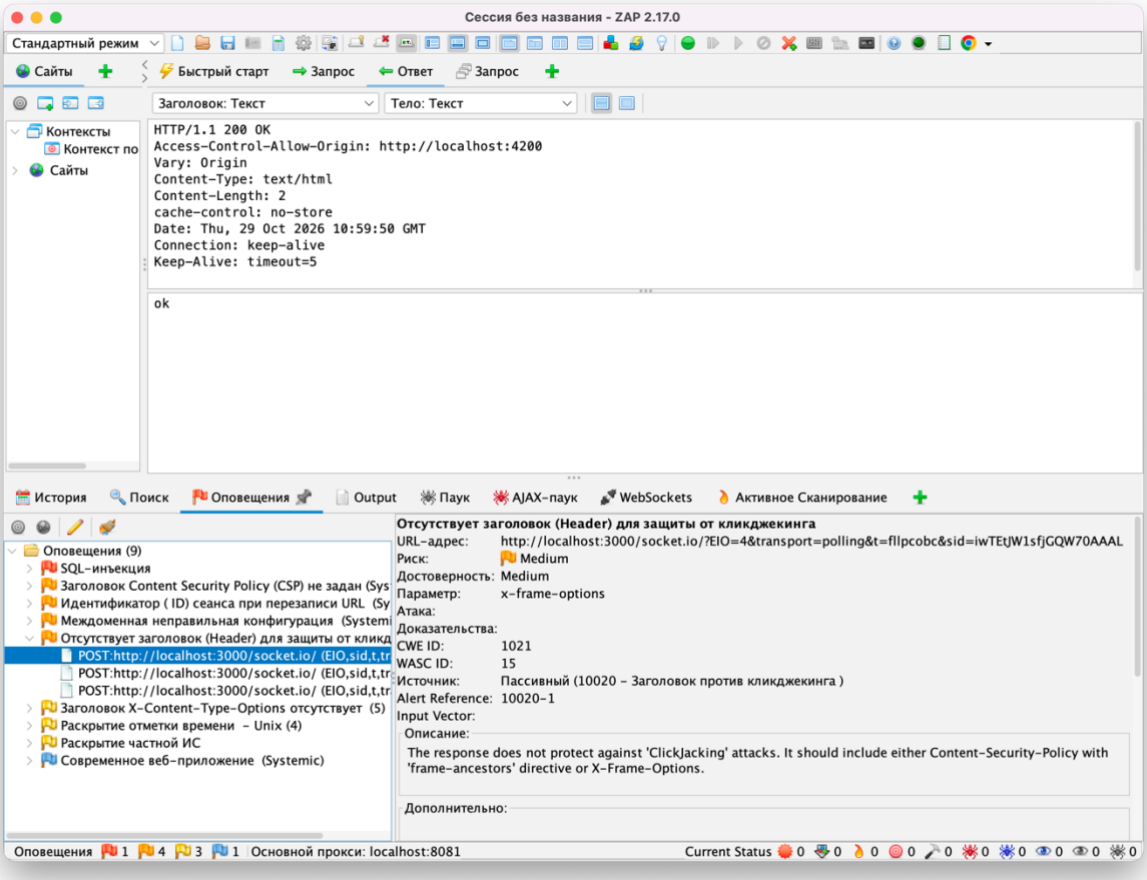
Для устранения проблемы рекомендуется настроить заголовок Content-Security-Policy, указав разрешённые источники загрузки ресурсов и выполнения скриптов.



При анализе HTTP-ответа сервера был обнаружен заголовок `Access-Control-Allow-Origin: *`, разрешающий чтение соответствующего ресурса со стороны произвольных веб-сайтов.

Такая конфигурация может представлять угрозу, если применяется к ресурсам, содержащим конфиденциальную информацию. В данном случае предупреждение обнаружено для публичного ресурса, поэтому фактическая утечка данных не подтверждена.

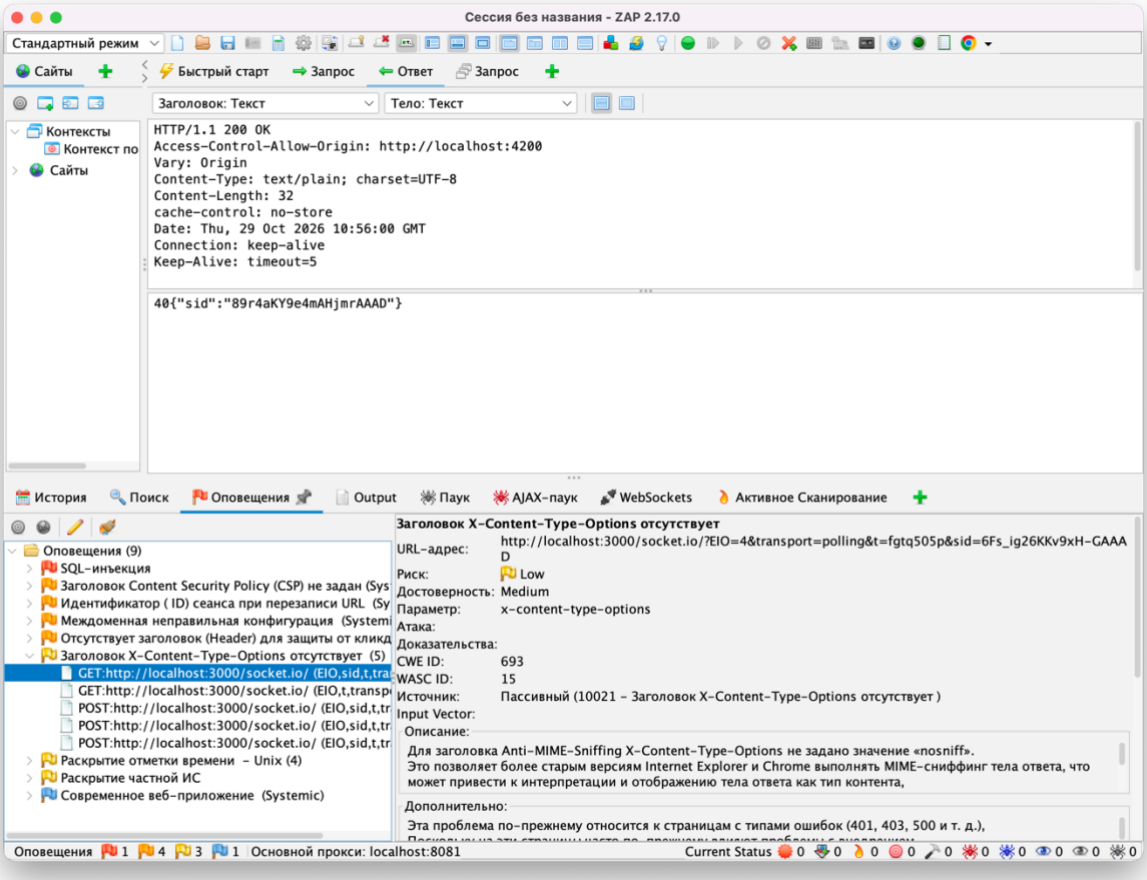
Для повышения безопасности рекомендуется ограничивать разрешённые источники CORS там, где это необходимо, и отдельно контролировать доступ к защищённым ресурсам.



При анализе HTTP-ответа по адресу `/socket.io/` было установлено отсутствие заголовка `X-Frame-Options`, а также политики Content Security Policy с директивой `frame-ancestors`.

Отсутствие данных механизмов может создавать условия для атаки Clickjacking, при которой злоумышленник встраивает интерфейс приложения в стороннюю страницу и обманом заставляет пользователя выполнять нежелательные действия. В данном случае возможность эксплуатации не была подтверждена.

Для устранения проблемы рекомендуется настроить заголовок `Content-Security-Policy` с директивой `frame-ancestors` или использовать `X-Frame-Options` для ограничения встраивания страниц



При анализе ответа сервера по адресу `/socket.io/` было установлено, что заголовок `X-Content-Type-Options` отсутствует.

Данный заголовок используется для предотвращения MIME-sniffing – попыток браузера самостоятельно определить тип содержимого ресурса. Отсутствие ограничения в отдельных ситуациях может привести к небезопасной интерпретации полученных данных.

Для устранения проблемы рекомендуется добавить HTTP-заголовок `X-Content-Type-Options: nosniff` и корректно указывать тип содержимого с помощью `Content-Type`.